

From a verification script to a governance system — and exactly where we stand

A complete visual brief of the authoritative state: what was built, what the hashes prove, who decides, and why a Mainnet broadcast remains **NOT AUTHORIZED** even though every test passes.

Binding decision — after the governance records

RELEASE APPROVED · BROADCAST LOCKED

The pinned release is approved under the **disclosed** single-operator mode; no transaction signing and no broadcast — the vault opens only with a **P7** signature from a named human operator.

C7 — Security review

APPROVED single-op

Accepted under the disclosed single-operator mode — risks R-1/R-2/R-3 accepted by name; upgrade to full independence via the external signature slot.

C8 — Evidence review

APPROVED single-op

H1-H8 re-derived from a real GitHub clone on Windows — upgrade to full independence via the external signature slot.

C9 — Owner decision

EXECUTED delegated

The approved release reference is pinned; transaction and broadcast authorization are deferred exclusively to P7.

SELF-002 — Engine hygiene

RESOLVED

exec=0 · net=0 · dyn=0 — a self-auditing AST check (ST21) inside SelfTest 21/21.

ENV-003 — Trust root

RESOLVED

cast.exe inside the trust root: 0xeba3df69... · v1.8.0 · official channel.

LEG-001 — Legacy quarantine

RESOLVED

19 legacy files quarantined byte-for-byte under legacy-quarantine/ — outside the scan roots.

Current freeze

46/46 MATCH

freeze-record-4.2.6 = 27 release + 19 quarantine entries · disk match proven.

Execution boundaries (no test result can override these):

RELEASE REFERENCE @ fa15eb2 = APPROVED (single-op)

TX SIGNING = NOT AUTHORIZED

COMMITINTENT = NOT AUTHORIZED

ANCHORPROOF = NOT AUTHORIZED

MAINNET BROADCAST = NOT AUTHORIZED

The rule that explains everything: passing tests grant no authorization. The verification tool holds no keys, reads no secrets, and cannot grant itself permission — the separation between the evidence, verification, review, authorization, and execution layers is what stops "33/33 PASS" from becoming an automatic broadcast. Even the original v06 failure (cast outside the trust root) was **correct behavior** to document, not a defect to hide.

Architecture: five layers, and execution is sealed

Evidence flows upward; authorization flows downward only through an explicit human signature at every gate. No layer can grant itself permission.

1 Evidence layer

SHA-256 from disk · 8/8 manifest · an immutable bundle during review · cumulative freeze records (4.2.2 → 4.2.6)

▲ evidence

2 Verification layer

The `cg-assurance-verify.ps1` engine (AST + policy + 16 fail-closed negative tests) · an independent Node validator (649 checks) · the single-byte tamper test

▲ reproducible results

3 Independent review layer

A human reviewer ≠ the author · recomputes every hash from disk personally · signs the H1–H8 matrix → closes C8 only

▲ signatures

4 Authorization layer

C7 (security) · C8 (independent) · C9 (an explicit owner decision, precisely scoped) · a separate GO record

▼ explicit, separate authorization only

5 Execution boundary 🔒

Signing and broadcast under separate, pre-reviewed human control — **currently sealed: NOT AUTHORIZED**

The three fixes: from fail-closed detection to closed proof

The v4.2.2-remediation cycle resolved the three blocking findings — each fix shown as before/after with inspectable evidence.

SELF-002 · Hygiene of the engine itself

Engine 2.1.0 carried two process invocation sites `exec:2` — a verification tool must not execute anything



v2.1.2:
`exec=0` ·
`net=0` · `dyn=0`
— a permission set which forbids that tool can do anything

Evidence: SelfTest → checks: 21; failures: 0 (exit 0) — re-run verbatim from the repository copy.

ENV-003 · The tool inside the trust root

V06 FAIL
(intentional) —
`C:\Users\DeLL-L\foundry\cast.exe`
outside the approved trust roots.



V06-2
...
`\.foundry\cast.exe`
`0xeba3df69...`
— a tool that is now inside the trust root
`foundryup` — a tool that is now inside the trust root

Evidence: item H6 in the packet + the standard run report: ENV-003=within-trust-root.

LEG-001 · Quarantining legacy broadcast paths

`cast send /`
`--private-`
`key /`
`anchor /`
`broadcast`
scripts loose in the tree — readable as an approved execution path

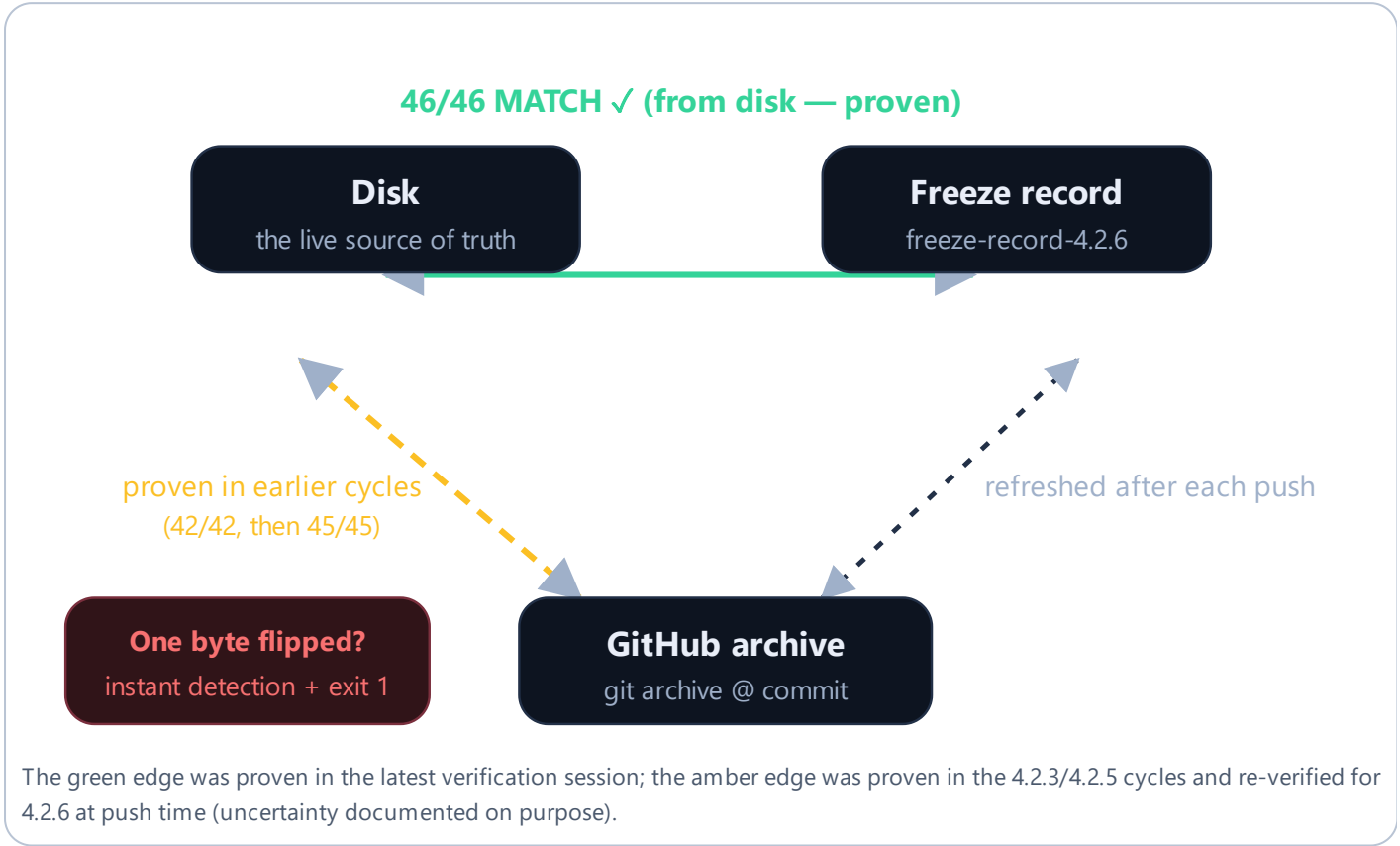


legacy-
`quarantine/2026-09-18-v4.2.2/`
`anchor/` ·
`broadcast-and-tests/` ·
`mainnet-gates/`

Evidence: the `orig|quarantine` pairs in the manifest (H5: 8/8 MATCH) prove byte preservation — quarantine is archival, never alteration.

The freeze: an integrity triangle and the one-byte test

The freeze record pins a SHA-256 for every file, from disk, at a moment in time. Its binding rule: **any edit after capture — even documentation — voids the freeze and demands a new cycle**. Every "did the bytes change?" dispute is therefore settled with a single command.



Freeze-verifier simulation — flip a byte, watch the rejection

The displayed content = the real cast hash. The button flips a single nibble and recomputes SHA-256 (in your browser) exactly as the verifier does on disk.

EBA3DF695D1C96CB54175183F89D62BAFAC7F728365987A1947743C6F3E91B36

SHA-256: be0692cdf379db32493bc06aaf4d5a124fdf12335692f71c72cc67a0ebc3309f

✓ MATCH — 46/46 • accepted (exit 0)

Anatomy of the actual record (fields present verbatim in freeze-record-4.2.6.json)

Field	Value / meaning
recordId / releaseId	cg41-freeze-record-4.2.6 · 4.2.6-overhaul — supersedes 4.2.5

Field	Value / meaning
frozenAtUtc	2026-09-18T09:31:01Z — after capture, no edits; the sole exception: re-pinning the README hash after an edit (documented, timestamp preserved)
sha256.releaseFiles + quarantineFiles	27 + 19 = 46 entries — entry shape: {file:"README.md", sha256:"0xba265f10...", bytes:1402}
excluded	exactly one — the record itself (self-referential); verified by a disk ↔ archive comparison
cycleEvidence	selftest 21/21 · negative 16/16 (precond=0) · validator 649 · a determinism proof (regeneration = byte-identical) · clean clone BLOCKED
decision	CONDITIONAL NO-GO — C7=PARTIAL C8=PENDING C9=PENDING; ... = NOT AUTHORIZED
gitCommit	present — pinning is commit-anchored (gitCommit = 2cdda4f2...) · the --disk mode is diagnostics only, never evidence

fail-closed semantics: a language that cannot be forged

A binding contract for engine 2.1.2 — developed after a negative scenario was found to "silently lose its precondition" while success was still being announced.

Status	Meaning	Counts as success in a mandatory negative scenario?
PASS	The condition genuinely held, with evidence	in expect-pass cases only
FAIL	A violation was caught by a closed check	Yes — that is the goal in expect-fail
BLOCKED	Could not proceed, blocker documented	Yes — provided the blocker is documented
INCONCLUSIVE	Insufficient evidence to judge	No
NOT_APPLICABLE	Not applicable, with a documented reason	No — ever (the old Scenario 9 defect)
PRECONDITION_FAILURE	A mandatory precondition was absent	Fails the whole cycle: exit 1

Golden rules shipped: NOT_APPLICABLE ≠ PASS · a missing manifest/evidence file = an explicit refusal, never a bypass · any unexplained difference halts the cycle and is never fixed by editing the report · the declared scenario count = the actual count (cosmetic Scenario 15 was removed: 17 → 16; the real failure it gestured at is covered by 14).

Evidence: the packet's literal commands and their verified outputs

Command text comes from the packet itself (packet 1.2.0) — each command is a single element that copies whole with one click (hashes at the full 64 hex chars, no ellipses, no wrapped lines). The last line is behavior display only and cannot be copied.

```
$ node verification/validate-freeze.mjs release/freeze/freeze-record-4.2.6.json
validate-freeze: PASS (46/46 MATCH)
exit 0 – historical records (4.2.2-4.2.5) intentionally fail: their pins are stale by design
$ powershell -NoProfile -ExecutionPolicy Bypass -File "verification/cg-assurance-verify.ps1" -SelfTest
checks: 21; failures: 0
exit 0 – includes ST21: zero execution sites in the engine (exec=0 net=0 dyn=0)
$ powershell -NoProfile -ExecutionPolicy Bypass -File "verification/cg-assurance-verify.ps1" -NegativeSuite -CastPath "C:\Users\DeLL-L
\foundry\cast.exe" -ExpectedCastSha256 "0xeba3df695d1c96cb54175183f89d62bafac7f728365987a1947743c6f3e91b36" -Manifest "release/v4.2.2
-remediation/approved-evidence-manifest-v4.2.2.txt" -ManifestBase "<repo-root>\coreguard" -ExpectedManifestSha256 "0x73649ed34461637ea
99eb6eb7ed985bd414916a7e64a760a3e360a69841be0dc"
negative suite: 16 scenarios; allFailClosed=True; preconditionFailures=0
exit 0
$ powershell -NoProfile -ExecutionPolicy Bypass -File "verification/cg-assurance-verify.ps1" -OutDir release -CastPath "C:\Users\DeLL-L
\foundry\cast.exe" -ExpectedCastSha256 "0xeba3df695d1c96cb54175183f89d62bafac7f728365987a1947743c6f3e91b36" -Manifest "release/v4.2.
2-remediation/approved-evidence-manifest-v4.2.2.txt" -ExpectedManifestSha256 "0x73649ed34461637ea99eb6eb7ed985bd414916a7e64a760a3e360a
69841be0dc"
status: VERIFIED-READONLY-ONLY · 33/33 PASS · ENV-003=within-trust-root · failClosedFailures=0
exit 0 – requires the reviews-extra evidence (deliberately outside the repo) · latest proof: the 4.2.6 cycle with the determinism
proof (regeneration = the frozen bytes verbatim)
$ powershell -NoProfile -ExecutionPolicy Bypass -File "verification/cg-assurance-verify.ps1" -SelfCheckReport
self-check: PASS – dupIds=0 · boundedClaim=True
$ node verification/validate-report.mjs release/verification-report.json --expect "{\"summary.total\":33,\"summary.pass\":33,\"summar
y.fail\":0,\"summary.blocked\":0,\"summary.inconclusive\":0,\"summary.notApplicable\":0,\"status\":\"VERIFIED-READONLY-ONLY\",\"decisi
on\":\"CONDITIONAL NO-GO\"}"
validate-report: PASS (649 checks, 0 errors)
Behavior display only – a clean clone without the reviews-extra evidence (not a command to run):
git clone github.com/EsIam-X/coreguard && a standard run inside the clone → BLOCKED · exit 1 · INV-001 FAIL (failClosed=true)
The intended behavior (Option B): external evidence lives outside the repository on purpose – the clone refuses to issue a PASS
verdict without evidence: no NOT_APPLICABLE, no bypass.
```

Negative test families (16 scenarios, every one of them must fail closed)

Byte integrity

one-byte edit · wrong hash · missing file · tampered
manifest / mismatched hash (NEG-wrong-manifest-hash)

RPC safety

a method outside the allow-list · the send verb · an empty
list (the closed POL-002 catalog)

Execution safety

double spawn · dynamic invocation
(scriptblocks/members)

Environment

cast outside the trust root · cast missing · insufficient
permissions

Report & policy integrity

duplicate IDs · a report edited after creation · a stale policy
/ mismatched hash · a tampered drift map (14)

Five freeze cycles — each one caught a real defect

This is the meta-proof that the governance works: no cycle ended without revealing something that would have gone unseen without the rule "any unexplained difference halts the cycle". All dates are 2026-09-18.

v4.2.2-remediation engine 2.0.0 → 2.1.0 **fixed: SELF-002 · ENV-003 · LEG-001**

- The full remediation cycle for the three blocking findings (above) + the C7/C9 templates and the reviewer packet.
- A later claim of "11 files changed after the freeze" was examined on disk (P6): both documentation files were **inside** the commit, and the tmp files were untracked — the report captures evidence, it does not rewrite it.

v4.2.3-post-change-validation engine 2.1.1 **caught: silent precondition loss**

- Deterministic comparison revealed Scenario 9 flipping from FAIL to `NOT_APPLICABLE` when the manifest precondition was missing — while "17/17" was still being announced.
- Fix: a fail-closed precondition guard. Re-freeze + an evidence-preservation proof for 4.2.2 (5/5 UNCHANGED).

v4.2.4-closure engine 2.1.2 **caught: mojibake + a cosmetic scenario**

- `PRECONDITION_FAILURE` → `exit 1` semantics; cosmetic Scenario 15 removed (17→16); the validator went 657→649.
- CI went red: the encoding detector rejected CP1252 mojibake in two freeze records (PowerShell 5.1 had read BOM-less scripts as ANSI) → reverse decoding + re-pinned hashes → `npm test 696/696` and CI green.

v4.2.5-closure engine 2.1.2 **caught: a stale internal manifest**

- Adopted "Option B" for external evidence — actually tested: a clean clone → `BLOCKED exit 1`, exactly as documented.
- 45 entries; during verification the internal `manifest.json` was found pinning pre-2.1.2 bytes → re-pinned.

v4.2.6-overhaul / prune engine 2.1.2 **closed: scope gaps + broken commands**

- README as the reviewer's entry point; fixed the literal H1-H8 commands (they still expected the old "17 scenarios / 657", and the negative command lacked preconditions — it would have failed any reviewer instantly); removed a duplicated documentation layer (3 files / 107 lines).
- Final prune: two dead links and a stale "49" in the README → corrected; the README hash was re-pinned → **46/46 MATCH** from disk.

The C8 packet: what does the independent reviewer sign?

The H1–H8 matrix (packet 1.2.0) — each item is an evidence binding that the reviewer verifies from disk personally, then signs. **A signature closes C8 only and grants no broadcast GO** — the owner decision (C9) is separate by construction.

Item	What it binds	Reference hash	Signature / date
H1	Engine v2.1.2 — after the SELF-002 fix (exec=0 net=0 dyn=0) and the PRECONDITION_FAILURE semantics	recomputed from disk	— awaiting —
H2	The standard run report: 33/33 PASS · VERIFIED-READONLY-ONLY · ENV-003 inside trust · LEG-001 clean	0xffb7b589...7a1c (46,812B)	— awaiting —
H3	The self-test TAP 21/21 (includes ST21, guarding against future execution sites)	0x1ebf06fa...2209 (705B)	— awaiting —
H4	The negative suite 16/16 fail-closed · precond=0 — after removing cosmetic 15 (its coverage: 14)	re-derived from disk (regenerated on 2.1.2)	— awaiting —
H5	The approved evidence manifest v4.2.2 — 8/8 MATCH with orig quarantine pairs (proof of byte preservation in quarantine)	0x73649ed3...e0dc (1,033B)	— awaiting —
H6	The V06-2 closure: cast path · SHA-256 · version 1.8.0 · official source · sole PATH entry · the documented absence of an Authenticode signature	0xeba3df69...91b36 (58,801,152B)	— awaiting —
H7– H8	The remaining packet items (completed at the actual reviewer handoff — not detailed here, to avoid claiming beyond what is proven)		

Before the packet is handed over, the remaining transition conditions must be complete: an independent tree (disk ↔ record ↔ archive match) · no unexplained PENDING/BLOCKER items · no stale hashes · no undocumented post-freeze changes.

The live governors page — who owns each gate, and who can upgrade it

The gates were executed under the **disclosed single-operator mode** (GOVERNANCE-MODE.md + GOVERNANCE-RECORDS.md): every record carries a mandatory disclosure header, a named approval source, and an **empty upgrade slot** — the first independent human signature upgrades the record to full independence **with zero rework**.



C7 — Security

APPROVED single-op

Threat model · fail-closed contract (16/16) · tamper in both modes · a read-only engine · quarantine 19/19 · no secrets · risks R-1/R-2/R-3 accepted **by name** · the F-1 structural finding deliberately open.

Signature source: GOVERNANCE-RECORDS.md · Record 1
Signer: the Acting Owner (Codebuff session) under owner delegation — **no independence claimed**

Independent upgrade slot — empty

a human security reviewer's signature upgrades the record and auto-closes F-1

C8 — Evidence

APPROVED single-op

H1–H8 re-derived from a real GitHub clone: archive 46/46 · Dec-C-9 under autocrlf=true · 21/21 · 657/0 · contract 13/13 · EX-1 CLOSED · EX-2 accepted.

Signature source: GOVERNANCE-RECORDS.md · Record 2
Signer: the Acting Owner (Codebuff session) under owner delegation — **no independence claimed**

Independent upgrade slot — empty

a human evidence reviewer's signature upgrades the record automatically

C9 — Owner decision

EXECUTED delegated

The approved release reference is pinned (fa15eb2) · expiry: anchor supersession or any signer filing a finding · revocation: an owner statement or an independent signature's refusal.

Decision source: GOVERNANCE-RECORDS.md · Record 3
Signer: the Acting Owner under owner delegation — the original decision belongs to the project owner

Independent ratification slot — optional

a human signature raises the decision's source from delegation to independent endorsement

P7 — Execution authorization (the vault)

NOT AUTHORIZED

Requires: a **named** human operator · a scope with value/gas ceilings · a personal signature — and keys never pass through this session or its tools.

Source: FINAL-GO-GATE.md · P7 — structurally separate from C9

The only slot that opens the vault

never filled electronically or by an agent — the operator's signature only

"Live" in an honest sense: this page is a generated snapshot — the binding source is the repository itself, and the links open the truth at the moment you click: [governance records](https://github.com/EslaM-X/coreguard/blob/main/coreguard-assurance-v4.2.2-remediation/GOVERNANCE-RECORDS.md) (https://github.com/EslaM-

X/coreguard/blob/main/coreguard-assurance-v4.2.2-remediation/GOVERNANCE-RECORDS.md) · [fa15eb2](https://github.com/EslaM-X/coreguard/commit/fa15eb26ebf4e1acde660b8a14ead534f3a40506) (https://github.com/EslaM-

X/coreguard/commit/fa15eb26ebf4e1acde660b8a14ead534f3a40506) · [CI — latest run 35402919848 \(5/5 ✓\)](https://github.com/EslaM-X/coreguard/actions) (https://github.com/EslaM-

X/coreguard/actions) · **validate-freeze: PASS 46/46 anchored @ c34cae8684c1**

The path to GO: nearly closed — one human operator signature separates us from opening the vault

closed — single-op C8 — Evidence approval

H1–H8 re-derived from a real GitHub clone (46/46 · 21/21 · 657/0) — upgrade to full independence from the signature slot on the governors page



closed — single-op C7 — Security

Threat model and boundaries reviewed · risks R-1/R-2/R-3 accepted by name — the independent audit remains in the upgrade slot



executed — delegated C9 — Owner decision

The approved reference pinned · a narrow scope · expiry and revocation defined — broadcast itself is not authorized



P6 recorded — 9/9 Final GO gate + the approved release record

The reference release approved under single-operator mode — execution authorization (P7) is the only open item



P7 — Execution authorization by a named human operator

A separate, bounded, pre-reviewed stage · the operator's personal signature — **NOT AUTHORIZED until then**

the only open item

What is not yet claimed — item by item, no varnish

Item	Evidence	Impact if addressed	Effort
Commit-anchored freeze record (closed)	Closed in the 4.2.6 cycle: <code>gitCommit</code> pinned, and the verifier hashes from the commit tree (<code>git show</code>), not the disk — detection adversarially tested (10 scenarios)	Every claim verifies with one command and resolves to an immutable tree — the "did the bytes change after the freeze?" class that consumed two cycles is structurally dead	minutes
External evidence not machine-defined	<code>reviews-extra</code> is absent from the record (text scan: false) — the Option B document was pruned away	A <code>requiredExternalEvidence</code> matrix (path + hash + source) turns Option B from prose into an inspectable contract	low
CI does not run the assurance cycle	<code>ci.yml</code> : <code>npm test</code> only — the <code>SelfTest</code> / negative suite / validator run manually	A CI step for the environment-independent branch + a determinism re-proof on every push: evidence monitored continuously, not momentarily	medium
JSON generated via PowerShell 5.1	CP1252 mojibake struck twice by the same mechanism (the 4.2.4 / 4.2.6 cycles) — the engine is 1,013 lines of PS	A Node generator beside <code>validate-report.mjs</code> kills the defect class for good (PS for checking, Node for data)	hours
Gate states duplicated across 4 documents	The C7/C8/C9 text lives in STATUS, the README, the record's decision, and the packet tail	A single <code>gates.json</code> source consumed by the validator, the README, and the HTML board (generated, never handwritten)	half a day
Push & archive verification (closed)	<code>HEAD = origin/main = fa15eb2</code> · a clean tree · the real GitHub archive (<code>main.tar.gz</code>) matches the pins 46/46	The triangle's amber edge closed by actual measurement — nothing left open on it	done

Stated uncertainty (deliberate, updated): the "33/33 standard run" remains sourced from the freeze record (not re-run, preserving the frozen outputs), while "657 checks" was re-run from a real clone; the disk↔archive edge was closed by an actual 46/46 measurement from the real archive; and the C7/C8/C9 records are now disclosure-carrying papers, upgradeable by independent signatures. Current limits: governance is single-op until the upgrades complete — no claim broader than the evidence.

CoreGuard Gate 4.1 — a verification tool only: no keys, no signing, no broadcast.

RELEASE = APPROVED (single-op) · C7/C8/C9 = EXECUTED (disclosed Acting Owner) · TX SIGNING &
BROADCAST = NOT AUTHORIZED – P7 human gate

A visual brief generated from session evidence and records — sources: freeze-record-4.2.6.json · GOVERNANCE-RECORDS.md ·
documented verification results